



Univesidad Galileo

Tecnico Full Stack

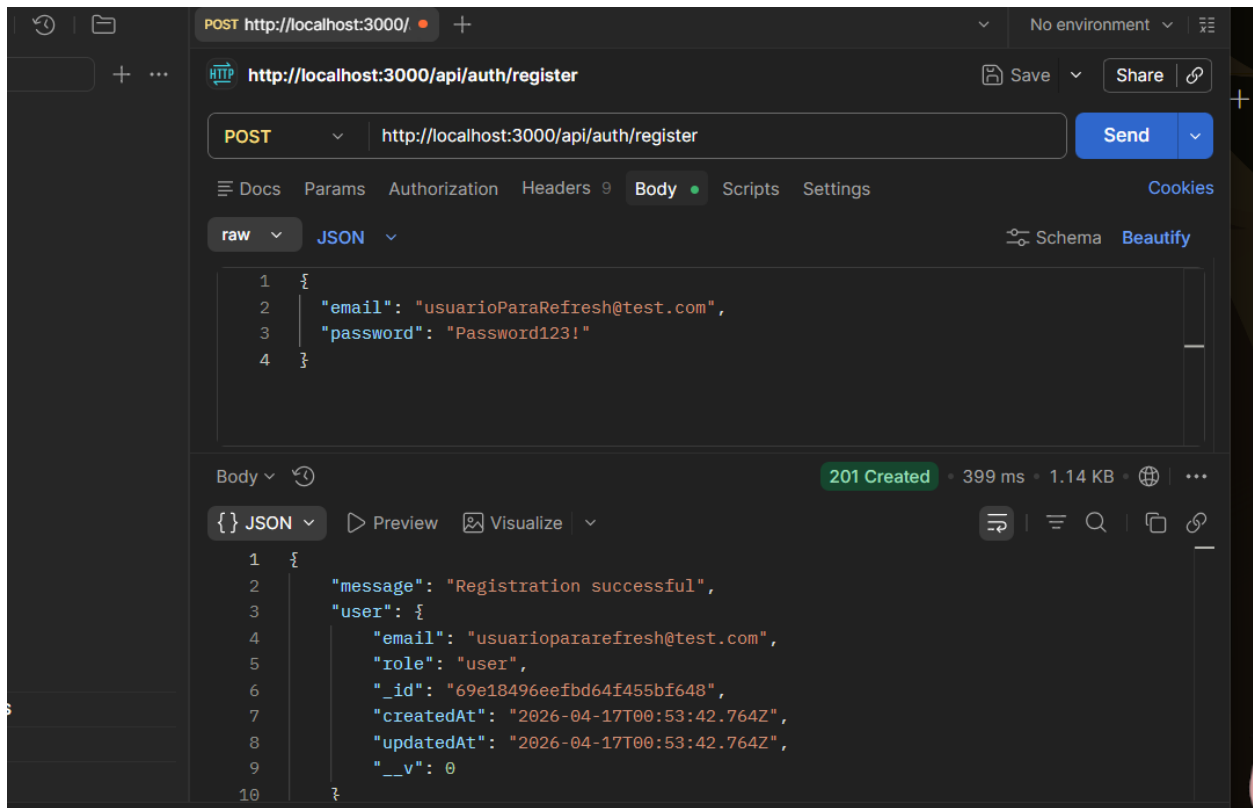
Curos: patrones de seguridad

Fecha de entrega: 16/04/2026

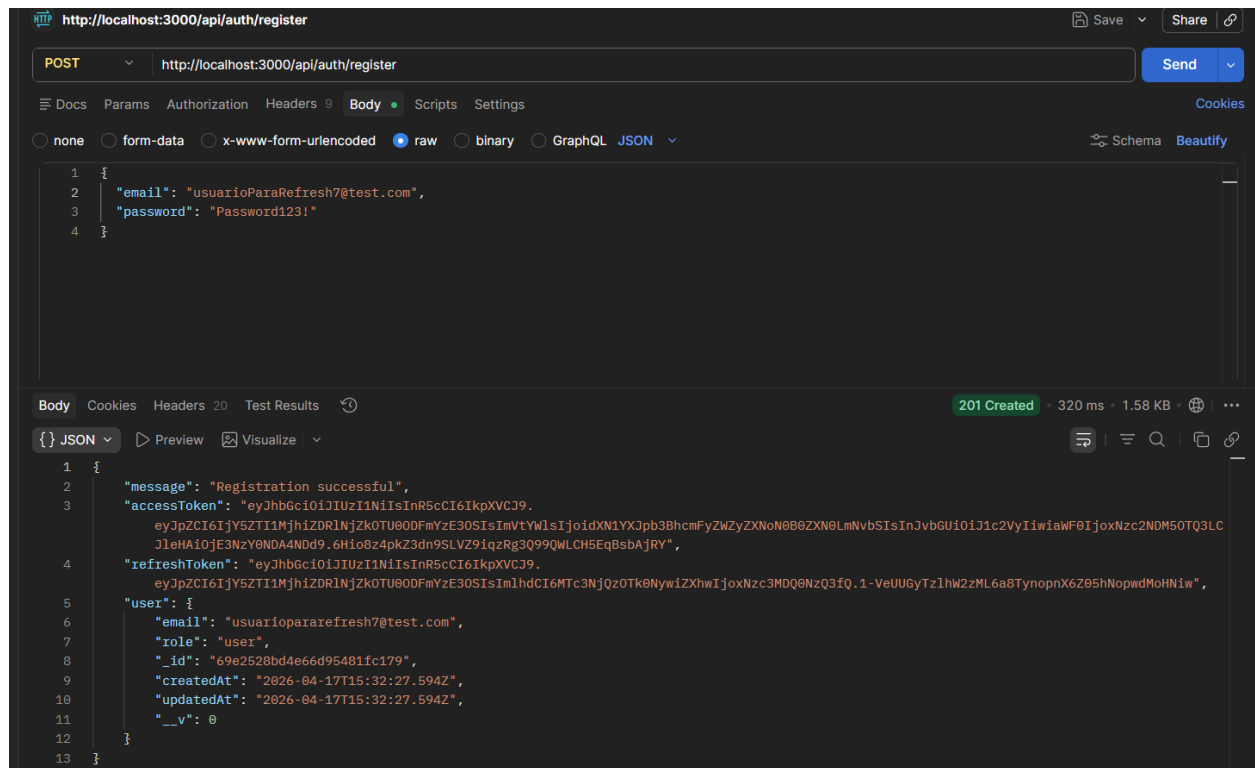
Implementacion del refresh token

Maidellin Suset Alvarado Cayax

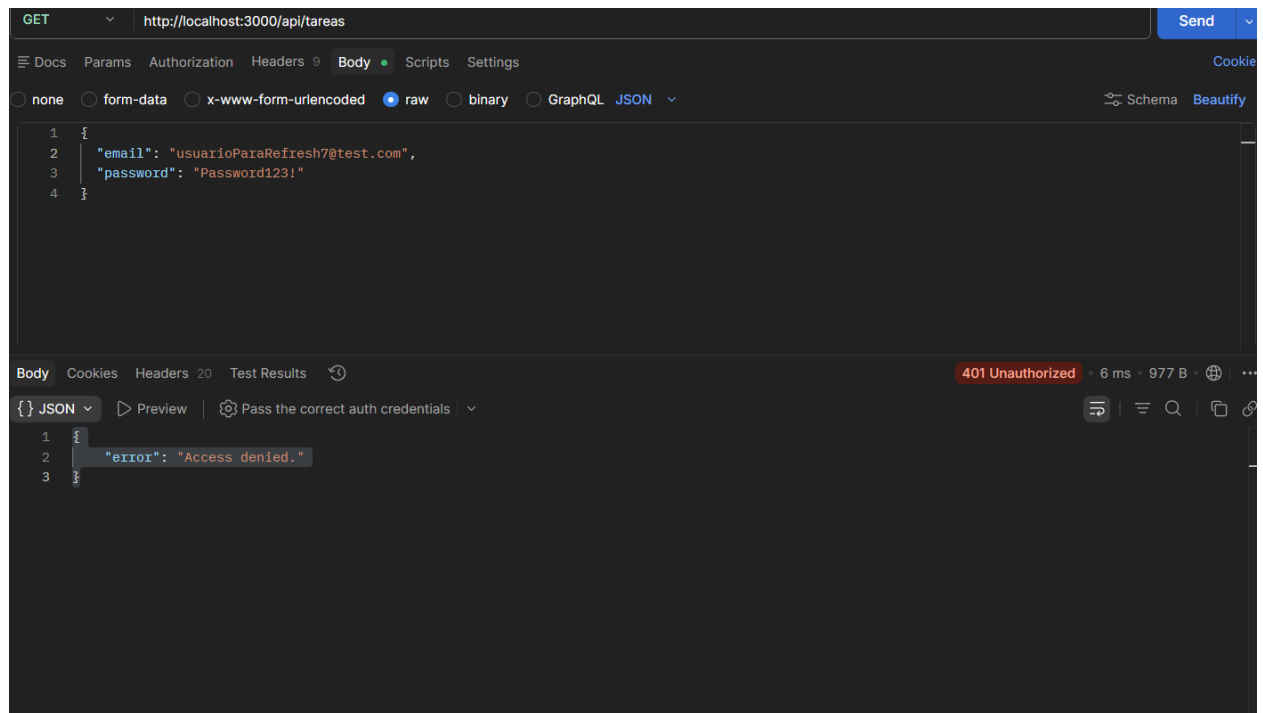
Test 1: Login devuelve accessToken + refreshToken



Creacion de un nuevo usuario con su token



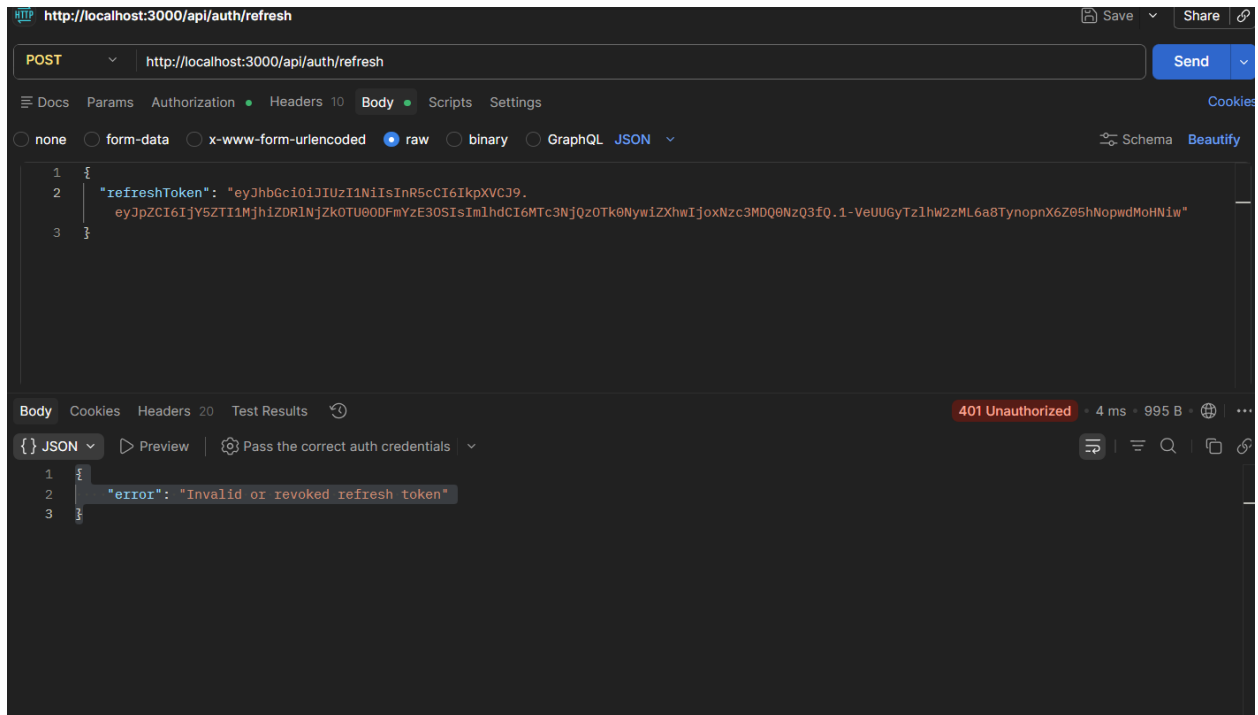
Incluimos ahora el token y refresh token.



en esta imagen quiero ver las tareas in autentificar entonces procedí agregar mi accessToken para identificarme y las muestra

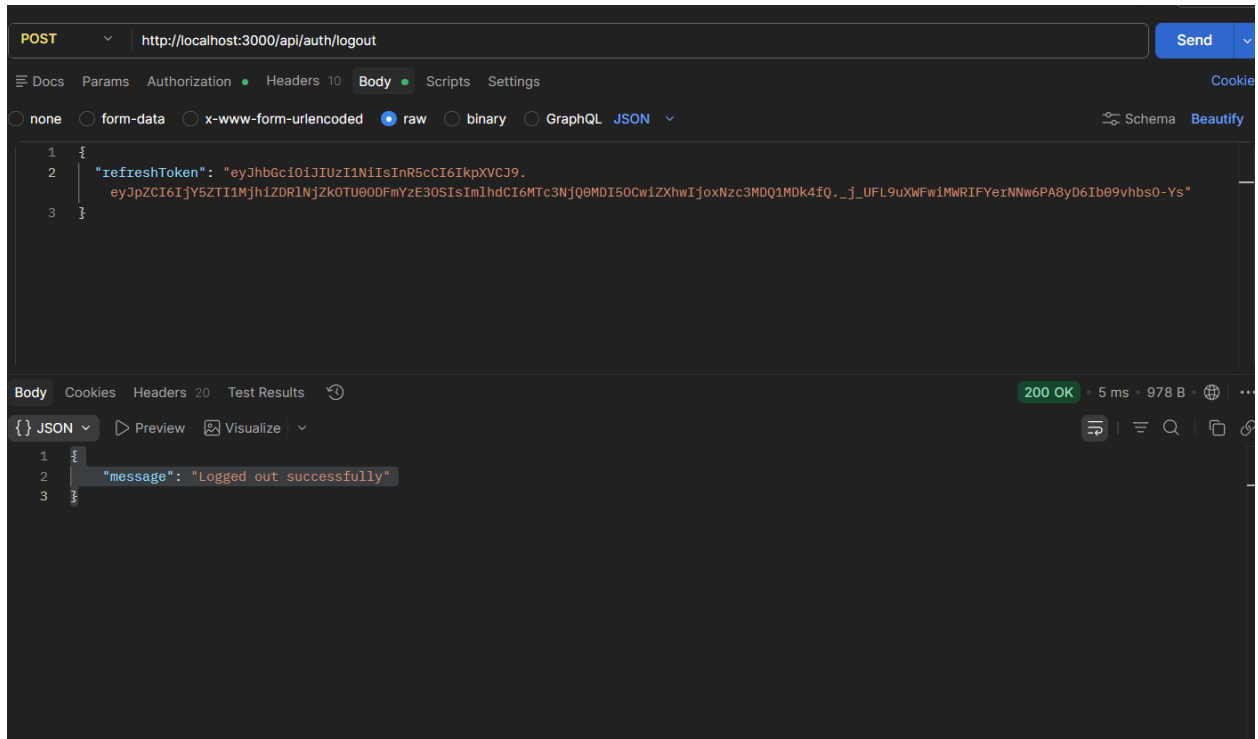
Si comparamos no es el mismo de la primera vez en la primera generación de refreshtoken

Test 4: Refresh token viejo es rechazado (rotacion)



Como ese token ya se usó (y nuestro código lo borró del Map()), el servidor ya no te debe dar tokens nuevos

Test 5: POST /logout invalida el refresh token



PEQUEÑO RESUMEN DE LAS PRUEBAS

Login devuelve DOS tokens

- Que al enviar credenciales correctas (email y password), el servidor nos entrega un accessToken y un refreshToken.

Access token funciona normal

- Hacer una petición a una ruta protegida (como `/api/tareas`) enviando el accessToken en los headers de autorización.
- Confirmar que tu middleware de seguridad sigue funcionando intacto. El servidor verifica la criptografía del token corto; si es auténtico y no ha expirado, te permite ver la información privada.

Refresh genera nuevos tokens

- Enviar el refreshToken válido a la ruta `/refresh` y recibir un nuevo par de tokens.

- Mejorar la experiencia del usuario (UX). Cuando el token de 15 minutos caduca. Así, el usuario puede usar la app todo el día sin que la pantalla lo obligue a escribir su contraseña cada 15 minutos.

Refresh token viejo es rechazado

Intentar enviar a /refresh el *mismo* token de la prueba anterior y comprobar que el servidor nos bloquea con un error de "inválido o revocado".

- Esta es la **Rotación de Tokens**. Garantiza que un refresh token sirva para *un solo uso*. Si un atacante logra robar el token de un usuario desde su navegador y lo intenta usar, el sistema lo detecta como un token ya "quemado" y detiene el ataque de inmediato.

Logout invalida el token

Enviar nuestro token activo a la ruta /logout para que el servidor lo elimine de su memoria.